

Risk Management Framework

Troy Fracyon

06/15/2025

1. How does the NIST Framework help to align risk management with other business objectives within an organization?

NIST frameworks are agreed upon and standardized rules and procedures to be used by organizations to help mitigate, prevent, and address risks. One of the primary goals of these frameworks is to have a well documented standardized critical process, so that the setup, maintenance, and recovery of systems are easily accessible and easy to understand to limit damages from risks. This helps keep critical structures functional so that they can help support the other systems that are reliant. There is also the benefit of bleed-over, where a stable practice form NIST may be adjusted and tailored for another unrelated structure.

2. What are the 7 Phases described in the NIST Risk Management Framework?

The seven phases described by the NIST Risk Management Framework are Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor. Prepare is the process of looking into one's own organization and understanding where you currently stand and steps need to be taken in the upcoming future. Categorize is taking all of your factors and ranking the severity of them to your organization's confidentiality, integrity, and availability. Select is the process of choosing which steps best fit with your scenario. Implement is taking the action to integrate your risk management decisions into your business system. Assess is calculating the effect of your risk management framework and see how things can be further improved. Authorized is the process of making these new systems valid within your business ecosystem. Finally, monitoring is watching your new frameworks over time and adjusting if needed.

3. Compare this Framework to another approach to Risk Management, find one through your own research.

Through my research, I have decided to research and compare NIST Risk Management Framework with the ISO 31000. The ISO/IEC 31000 risk management framework is an international standard that provides guidelines and principles to organizations that focus on the topics of governance, management, planning, values, and culture. There are eight design principles of the ISO 31000 including Integrated, Structured & comprehensive, Customized, Inclusive, Dynamic, Best available information, Human & cultural factors, and continual Improvement. Integrated means that all risks should be managed by all leaders, employees, and stakeholders. Structured & comprehensive

is the idea that all processes should be organized to be maintained and understood easily. Customized means that each system is fitted to the specifics of the organization. Inclusive is the idea that the risk management should take account the points of views of everyone associated to garnish a wider approach over time. Dynamic means that the system should be updated regularly to fit the rapidly changing contexts of an organization. Best available information means that there should always be an attempt to gain new information and better understand old facts. Finally, continual improvement is maintaining relevance to support organizational goals.

There are also 5 frameworks behind the ISO 31000 that are used by organizations including Integration, Design, Implementation, Evaluation, and Improvement. The first framework is integration, which is the introduction process of a new practice in an organization. Design is taking your business context and building what you specifically need to address. Implementation is putting into practice the new designs and practices into your system. Evaluation is the grading process to measure performance. Finally, Improvement is taking your metrics and taking the appropriate actions to further improve your system.

Finally, there are six standards for ISO 31000 risk management process including Scope/context/criteria, Risk assessment, Risk treatment, Communication & consultation, Monitoring & review, and Recording & reporting. Scope is considering the context of the organization and understanding the goals. Context is used to help understand where things can be effectively implemented. Criteria is the type of risk and the amount of risk an organization is willing to accept. Risk assessment is the process of identifying, analyzing, and evaluating business risk. Risk treatment is understanding the options to address the risk. Communication and consulting is done throughout the whole process, where everyone is told what to expect and what needs to be done as a result of certain risks. Monitoring and reviewing is assuring the system stays effective over time. Finally, recording and reporting is the documentation process, where everyone stays informed and reference points are made for future use.

4. What are some similarities?

There are many similarities with the comparison of NIST and ISO 31000, including structures that address the before, during, and after procedures to risk. They both have beginning stages that evaluate current structures and use that information to develop plans to introduce the next best

integration steps. Another similarity is the emphasis of maintaining documentation of how things are going, in order to help understand what is needed to improve and change if at all.

5. What are some differences?

The biggest difference between NIST and ISO 31000 is the context of application. My biggest takeaway is that NIST is mostly tailored to IT systems while ISO 31000 can include many other types of business structures. A big difference with ISO 31000 is the value for company culture as a reference for business structures.

6. In your conclusion please explain if RMF or the other Risk Management approach is better or not.

With the understanding of how contextually, the implications of both risk management frameworks, I would say specifically as a technical IT-centric system, the NIST is a better risk management framework. However, when it comes to a large scale business model, there are many valuable tools that cross over to other aspects of an organization.

References

CSF 1.1 Uses and benefits of the Framework | NIST. (2024, February 26). NIST.

<https://www.nist.gov/cyberframework/uses-and-benefits-framework>

Decker, J. (2025, June 15). *How to apply the 7 Risk Management Framework (RMF) Process steps*.

IPKeys. <https://ipkeys.com/blog/rmf-steps/>

ISO/IEC 31000 for Risk Management | Splunk. (n.d.). Splunk.

https://www.splunk.com/en_us/blog/learn/iso-31000.html

Olaes, T. (2025, January 17). *What is NIST Cybersecurity Framework (CSF) 2.0?* | Balbix. Balbix.

<https://www.balbix.com/insights/nist-cybersecurity-framework/>

The NIST Cybersecurity Framework (CSF) 2.0 (2.0). (2014). [Online pdf]. National Institute of

Standards and Technology. <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>